

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check 12.2.2 + Maven 3.9.16) · Generated 2026-06-19 · SHA: 61ed8c3

Summary

Metric	Count
Dependencies scanned	24
Vulnerable dependencies	9
Total CVEs found	73
CRITICAL severity deps	2
HIGH severity deps	4
MEDIUM severity deps	3
LOW severity deps	0
Outdated dependencies	8
License warnings	2
Supply-chain alerts	2

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core` (groupId missing "er"). The coordinate does not exist on Maven Central. Maven 3.8+ blocks resolution but the declaration is still a supply-chain confusion vector. **Remove immediately.**

HIGH — Insecure repository source. `http://insecure-mirror.example.net/maven2` is declared in `pom.xml` and served over plain HTTP. An attacker with network access can substitute arbitrary artifacts via MITM. Maven 3.8 default HTTP-blocker currently prevents resolution, but the declaration must be removed.

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	CVE Count	Fix Version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	8	2.17.2
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	54	2.14.0
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	1	8.0.33
com.google.protobuf:protobuf-java	3.19.4	CVE-2024-7254	7.5	HIGH	4	3.25.3

org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2	2.17.2
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	2	32.1.1-jre
com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	MEDIUM	1	2.14.0
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2	2.15.1
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	1	3.17.0

CVE detail — log4j-core 2.14.1 (Log4Shell)

CRITICAL — Log4Shell (CVE-2021-44228, CVSS 10.0). Remote code execution via JNDI lookup injected into log messages. One of the most severe vulnerabilities in Java ecosystem history. Any application passing attacker-controlled strings to a log4j logger is exploitable. `DiscountCalculator.java` uses `LogManager.getLogger()` directly in the invoice/payment service. Upgrade to 2.17.2 immediately.

CVE	CVSS	Severity	Description
CVE-2021-44228	10.0	CRITICAL	Log4Shell — JNDI RCE via log message lookup
CVE-2021-45046	9.0	CRITICAL	Log4Shell bypass — incomplete fix in 2.15.0
CVE-2026-34479	7.5	HIGH	Log4j 2.x vulnerability (2026)
CVE-2026-34480	7.5	HIGH	Log4j 2.x vulnerability (2026)
CVE-2021-44832	6.6	MEDIUM	RCE via crafted configuration
CVE-2026-34477	5.9	MEDIUM	Shared log4j API vulnerability
CVE-2021-45105	5.9	MEDIUM	Infinite recursion / DoS
CVE-2025-68161	4.8	MEDIUM	Log4j 2.x vulnerability (2025)

CVE detail — jackson-databind 2.9.8 (54 CVEs)

CRITICAL — Unsafe deserialization gadget chains (jackson-databind 2.9.8). Fifty-four CVEs affect this artifact, including 14 CRITICAL-rated remote code execution vulnerabilities enabled by polymorphic type handling (`enableDefaultTyping`). The entire 2.9.x line reached end-of-life in 2021. Upgrade to 2.14.0 or later.

CVE	CVSS	Severity
CVE-2019-14379	9.8	CRITICAL
CVE-2019-14540	9.8	CRITICAL
CVE-2019-14892	9.8	CRITICAL
CVE-2019-14893	9.8	CRITICAL
CVE-2019-16335	9.8	CRITICAL
CVE-2019-16942	9.8	CRITICAL
CVE-2019-16943	9.8	CRITICAL
CVE-2019-17267	9.8	CRITICAL
CVE-2019-17531	9.8	CRITICAL

CVE-2019-20330	9.8	CRITICAL
CVE-2020-8840	9.8	CRITICAL
CVE-2020-9546	9.8	CRITICAL
CVE-2020-9547	9.8	CRITICAL
CVE-2020-9548	9.8	CRITICAL
CVE-2020-10672	8.8	HIGH
CVE-2020-10673	8.8	HIGH
CVE-2020-10968	8.8	HIGH
CVE-2020-10969	8.8	HIGH
CVE-2020-11111	8.8	HIGH
CVE-2020-11112	8.8	HIGH
CVE-2020-11113	8.8	HIGH
... +33 more	—	HIGH / MEDIUM

Outdated dependencies

Dependency	Current	Latest	Update Type
org.apache.logging.log4j:log4j-core	2.14.1	3.0.0-beta3	major
org.apache.logging.log4j:log4j-api	2.14.1	3.0.0-beta2	major
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.22.0	minor
com.google.guava:guava	24.1.1-jre	33.6.0-jre	major
commons-io:commons-io	2.4	2.22.0	minor
mysql:mysql-connector-java	8.0.30	8.0.33	patch
org.apache.commons:commons-lang3	3.4	3.20.0	minor
org.junit.jupiter:junit-jupiter	5.10.2	6.1.0	major

License analysis

Dependency	License	Status
mysql:mysql-connector-java	GPL-2.0 (FOSS exception)	WARN
org.checkerframework:checker-compat-qual	GPL-2.0-with-classpath-exception	WARN
All other compile deps	Apache-2.0 / MIT / BSD-3-Clause / EPL-2.0	OK

Machine-readable source: `depscan-report.json` (source_sha: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`). Generated by the Dependency & Supply-Chain Plugin — Stage 1.